

VULNERABILITIES & THREATS

Security experts advise 'immediate' patching of critical DNS client vulnerabilities in Windows 8, 10, and other affected systems.



Kelly Jackson Higgins, Editor-in-Chief, Dark Reading

October 10, 2017

3 Min Read

DARK
READING

Microsoft today issued patches for three critical vulnerabilities in the Windows DNS client in Windows 8, Windows 10, and Windows Server 2012 and 2016 that ironically came via a security feature.

The heap buffer-overflow flaws discovered by researchers at Bishop Fox – and [fixed](#) via the new CVE-2017-11779 [security update](#) amid [Microsoft's October Patch Tuesday batch](#) – could allow an attacker to wrest away full control of the targeted Windows machine without the victim taking any action at all. The bugs were found specifically in Microsoft's implementation of one of the data record features used in the secure Domain Name System protocol, DNSSEC.

DNSSEC is a security layer for DNS that digitally signs and validates a DNS so it can't be spoofed.

Nick Freeman, the Bishop Fox researcher who discovered the vulnerabilities, says Microsoft's implementation of the NSEC3 (Next Secure Record version 3) feature for DNSSEC is the culprit. It's not surprising to find such a flaw, he says, because whenever a new security technology is added to software, it opens the door for implementation weaknesses. "Microsoft's implementation was poor" due to improper vetting of the format of the DNSSEC messages, says Freeman, who is a senior security associate with Bishop Fox.

DARKREADING

Explore more

From Reactive to Proactive: How Allowlisting Turns the Tables on Zero-Day Vulnerabilities

[Read More >](#)

Taking the Uncertainty Out of Cyber Recovery for Nutanix AHV Environments

[Read More >](#)

What Issues and Challenges Cybersecurity Pros Care About

[Read More >](#)

"It wouldn't surprise me at all if other [vendors' DNSSEC] implementations" had vulnerabilities as well, he says.

But unbeknownst to Bishop Fox, another researcher, Nelson William Gamazo Sanchez of Trend Micro's Zero Day Initiative, also had found and reported the flaws to Microsoft. The software giant credited both Freeman and Sanchez in its security update acknowledgements section.

For an attacker to exploit the DNSSEC vulnerabilities in Windows, he or she would need to be sitting on the same physical network as the targeted machine: that means a malicious insider, or an outsider who sets up a man-in-the-middle attack to intercept DNS requests from the victim's machine. DNS requests can be anything from browsing the Internet, checking email, or even the machine performing its own lookups for software updates.

The attacker could then respond to the Windows DNS requests with malicious data that would elicit the vulnerabilities and corrupt the memory of the DNS client. It then would allow him or her to control the DNS flow, and ultimately gain control of the victim machine. "If someone was using a corporate laptop at a coffee shop and on WiFi, or hacked your cable router and you got hit ... giving the attacker an entry point into the [corporate] network," Freeman says. "They could then launch this attack against other systems on that network."

The best protections from such an attack: steer clear of public WiFi or use a VPN while connected to it.

DNS security is typically an afterthought at most organizations, mainly because DNS is a relatively invisible network function behind the scenes that's taken for granted. A recent survey found that three out of 10 companies have been hit with cyberattacks on their DNS infrastructure: and that's only the organizations that actually are aware of these attacks.

It's been nearly one year since the massive DDoS attack on Domain Name Service (DNS) provider Dyn that [disrupted major websites](#) including Amazon, CNN, Netflix, Okta, Pinterest, Reddit, and Twitter.

Bishop Fox researchers, meanwhile, say they haven't seen signs of the Windows DNS flaws being abused by attackers yet. They recommend "immediate" patching of vulnerable Windows machines to protect against such attacks, and released [a detailed technical report](#) on the findings.

"This is a very traditional vulnerability, so it's reasonable" for most attackers to be able to exploit it, Freeman says.

Related Content:

[DNS a 'Victim of its Own Success'](#)

[2016 DDoS Attack Trends By The Numbers](#)

[Debunking 5 Myths About DNS](#)

[Domain Abuse Sinks Anchors of Trust](#)



November 29-30, 2017
Gaylord National Resort
& Convention Center, MD

Join Dark Reading LIVE for two days of practical cyber defense discussions. Learn from the industry's most knowledgeable IT security experts. Check out the INsecurity [agenda here](#).

About the Author



Kelly Jackson Higgins, Editor-in-Chief, Dark Reading

Kelly Jackson Higgins is the Editor-in-Chief of Dark Reading. She is an award-winning veteran technology and business journalist with more than two decades of experience in reporting and editing for various publications, including Network Computing, Secure Enterprise Magazine,